

Toolkit

Toolkit - turtlesec-software, GitHub.

- Published: date not stated
- Original: <<https://github.com/turtlesec-software/crlf-desyncs>>
- Preserved from: <https://github.com/turtlesec-software/crlf-desyncs> (git) on 2026-08-15
- Repository commit: da6c9a11ba7d805e94d0379002106e19bee05d5a
- Licence: see the repository

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

This reference is a source-code repository. The archive preserves its documentation at an exact commit; the code itself stays in a private mirror and is never checked out, built or run.

- Repository: <<https://github.com/turtlesec-software/crlf-desyncs>>
- Commit: da6c9a11ba7d805e94d0379002106e19bee05d5a
- Documents preserved: 1

README.md

Blob fbe417fe8dba, 1174 bytes, at commit da6c9a11ba7d.

CRLF Desyncs

This is a repository containing useful tools and resources for detecting and exploiting CRLF-based Desyncs, presented at BlackHat USA 2026 and DEFCON 34.

Contents

- `cdn-origin/` -> contains aggregated origin-to-edge headers useful for fuzzing a CRLF injection on a response.
- `nuclei-templates/` -> collection of nuclei templates which can help detecting CRLF injections at scale.
- `cookier.py` -> util script to easily format a CRLF-based cookie tossing payload.
- `header-name-wordlist.txt` -> custom large header wordlist for fuzzing weird behavior when dealing with a CRLF injection.

- `iframe.html` -> attacker page for exploiting browser powered tunneling in iframes (useful against weak SameSite cookie settings).
- `popup.html` -> attacker page for exploiting browser powered tunneling using refreshing popup windows.

Contributions

Contributions are more than welcome! Found a new detection technique? Please make a PR.

Also we would love to hear about fun cases you managed to exploit with this technique, if you want you can DM or tweet at us on X: [@m4st3rspl1nt3r](#) & [@t0xodile](#)

Archived from <https://github.com/turtlesec-software/crlf-desyncs>. Rendered offline from the local Markdown copy.